

Báo cáo review GitHub REST API

REST API endpoints for users

1. Đối tượng

Đối tượng: GitHub REST API công khai.

Phạm vi: Mục REST API endpoints for users, phiên bản API 2026-03-10, gồm sáu thao tác:

- GET /user
- PATCH /user
- GET /user/{account_id}
- GET /users
- GET /users/{username}
- GET /users/{username}/hovercard

Lý do lựa chọn đối tượng: Do GitHub REST API có số lượng endpoint lớn, việc khảo sát toàn bộ API với bằng chứng cụ thể là rất khó khăn. Vì vậy, nhóm thu hẹp phạm vi vào mục Users (/rest/users/users), nơi tập trung các nghiệp vụ tiêu biểu liên quan đến người dùng. Phạm vi này đủ đa dạng để đánh giá cục bộ cách GitHub thiết kế và tài liệu hóa API với một nghiệp vụ cụ thể.

Lưu ý: Kết quả khảo sát được xem là nhận xét cục bộ trong phạm vi Users, không đại diện cho toàn bộ GitHub REST API.

2. Kết quả khảo sát

1. Dùng danh từ để biểu diễn tài nguyên trong URL - Đạt

Yêu cầu: URLs chỉ chứa danh từ, không động từ. Method diễn đạt action.

Đánh giá: Cả sáu endpoint dùng danh từ trong đường dẫn, còn thao tác được thể hiện bằng HTTP method. hovercard là tên một thành phần giao diện, nhưng vẫn là danh từ.

2. Naming nhất quán - Chưa đạt hoàn toàn

Yêu cầu: Lowercase, kebab-case path; snake_case query; plurals cho collection.

Đánh giá: Phần lớn endpoint tuân thủ quy ước đã chọn; ngoại lệ là GET /user/{account_id}. Cả GET /user/{account_id} và GET /users/{username} đều tra cứu một phần tử trong collection người dùng, nhưng dùng tiền tố khác nhau. Đây là điểm chưa nhất quán trong naming.

3. Status code đúng nghĩa - Đạt

Yêu cầu: Mỗi response dùng code phù hợp. Không trả 200 + error trong body.

Đánh giá: Các endpoint khảo sát dùng status code để phân biệt phản hồi thành công, lỗi xác thực/phân quyền, tài nguyên không tồn tại, lỗi validation và conditional request.

4. Idempotency rõ ràng - Chưa đủ cơ sở kết luận

Yêu cầu: POST cần Idempotency-Key. PUT/DELETE idempotent. Tài liệu hóa rõ.

Đánh giá: Phạm vi khảo sát không có POST, PUT hoặc DELETE nên các yêu cầu riêng cho những method này không áp dụng. PATCH /user là endpoint cập nhật duy nhất; tài liệu mô tả các trường cập nhật nhưng không nêu rõ cam kết idempotency hoặc hướng dẫn retry an toàn. Vì vậy, chưa đủ cơ sở kết luận về idempotency của PATCH /user; không suy ra kết luận chỉ từ method hoặc việc gửi lại cùng dữ liệu.

5. Error response có cấu trúc - Chưa đạt

Yêu cầu: RFC 7807 problem+json nhất quán. Có type, title, detail, instance.

Đánh giá: Trong các phản hồi lỗi đã kiểm tra trực tiếp (HTTP 401 và 404), Content-Type là application/json; body có message, documentation_url và status nhưng thiếu type, title, detail, instance. Các phản hồi này chưa đáp ứng cấu trúc theo checklist. Kết luận chỉ áp dụng cho các mẫu lỗi đã kiểm tra, không khái quát cho mọi phản hồi lỗi; chưa kiểm tra lỗi 422 sau xác thực.

6. Pagination rõ ràng - Đạt

Yêu cầu: Collection nào cũng có phân trang (cursor/offset). Có giới hạn trên.

Đánh giá: Endpoint GET /users hỗ trợ phân trang bằng tham số since, dùng user ID làm cursor và Link header để cung cấp URL trang tiếp theo. Tham số per_page mặc định là 30, tối đa là 100. Các endpoint còn lại trong phạm vi khảo sát không trả về collection nên không áp dụng phân trang.

7. Filter/Sort đa dạng - Chưa đạt

Yêu cầu: Hỗ trợ lọc theo field chính, sort đa field, sparse fieldsets.

Đánh giá: Endpoint GET /users không ghi nhận khả năng lọc theo nhiều thuộc tính, tham số sort tùy chọn, sort đa trường hoặc sparse fieldsets. Tham số since phục vụ phân trang, không phải bộ lọc đa thuộc tính. Các tham số subject_type và subject_id của endpoint hovercard chỉ bổ sung ngữ cảnh. Các endpoint còn lại trả về một tài nguyên nên không áp dụng filter/sort cho collection.

8. Authentication & Security - Đạt

Yêu cầu: Token ở header. Không lộ qua URL. Rate limit rõ ràng.

Đánh giá: Tài liệu hướng dẫn truyền token qua Authorization header và quy định yêu cầu xác thực, quyền truy cập theo từng endpoint. Các request này tuân theo chính sách rate limit rõ ràng của GitHub REST API.

9. Versioning + Deprecation - Chưa đạt hoàn toàn

Yêu cầu: Có version prefix từ đầu. Có lộ trình ngừng hỗ trợ rõ ràng.

Đánh giá: Sáu endpoint sử dụng API version qua header X-GitHub-API-Version, không có version prefix trong URL nên chưa đáp ứng đầy đủ checklist. GitHub có chính sách hỗ trợ và ngừng hỗ trợ theo API version, sử dụng Deprecation/Sunset và phản hồi 410 Gone khi phiên bản hết hỗ trợ. Phiên bản 2026-03-10 chưa có ngày kết thúc hỗ trợ được công bố; điều này không tự nó chứng minh thiếu lộ trình ngừng hỗ trợ. Điểm chưa đáp ứng nằm ở yêu cầu version prefix trong URL.

3. Bảng chứng cụ thể

1. Dùng danh từ để biểu diễn tài nguyên trong URL - Đạt

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
GET /user	Path dùng danh từ; thao tác nằm ở HTTP method	user là danh từ; GET biểu thị thao tác đọc.
PATCH /user	Path dùng danh từ; thao tác nằm ở HTTP method	user là danh từ; PATCH biểu thị thao tác cập nhật.
GET /user/{account_id}	Path dùng danh từ; thao tác nằm ở HTTP method	user là danh từ; account_id là tham số định danh, không phải động từ.
GET /users	Path dùng danh từ; thao tác nằm ở HTTP method	users là danh từ chỉ collection; GET biểu thị thao tác liệt kê.
GET /users/{username}	Path dùng danh từ; thao tác nằm ở HTTP method	users là danh từ; username là tham số định danh.
GET /users/{username}/hovercard	Path dùng danh từ; thao tác nằm ở HTTP method	users và hovercard là danh từ; path không chứa động từ. hovercard là tên một thành phần giao diện.

2. Naming nhất quán - Chưa đạt hoàn toàn

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
GET /user	Lowercase; kebab-case cho path; snake_case cho query; số nhiều cho collection	Path /user viết thường. Segment tĩnh chỉ có một từ, không cần dấu phân cách. Endpoint không có query parameter. /user là singleton của người dùng đang xác thực.

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
PATCH /user	Lowercase; kebab-case cho path; snake_case cho query; số nhiều cho collection	Path /user viết thường. Segment tĩnh chỉ có một từ, không cần dấu phân cách. Endpoint không có query parameter. /user là singleton của người dùng đang xác thực.
GET /user/{account_id}	Lowercase; kebab-case cho path; snake_case cho query; số nhiều cho collection	Path viết thường; account_id là tên tham số. Segment tĩnh user là một từ; account_id là tên tham số, không phải segment tĩnh. Endpoint không có query parameter. Dùng tiền tố user số ít để tra cứu một user theo ID; khác với /users/{username}.
GET /users	Lowercase; kebab-case cho path; snake_case cho query; số nhiều cho collection	Path /users viết thường. Segment tĩnh users chỉ có một từ. since là một từ; per_page dùng snake_case. /users là collection và dùng số nhiều.
GET /users/{username}	Lowercase; kebab-case cho path; snake_case cho query; số nhiều cho collection	Path và tên tham số viết thường. Segment tĩnh users và tham số username đều là một từ. Endpoint không có query parameter. /users dùng số nhiều để truy cập một phần tử trong collection.
GET /users/{username}/hovercard	Lowercase; kebab-case cho path; snake_case cho query; số nhiều cho collection	Toàn bộ path viết thường. Các segment tĩnh users, hovercard và tham số username đều là một từ. subject_type và subject_id dùng snake_case. users là collection số nhiều; hovercard là tài nguyên con đơn.

3. Status code đúng nghĩa - Đạt

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
GET /user	Status code phù hợp với kết quả	200 thành công; 401 chưa xác thực; 403 bị từ chối; 304 khi conditional request không đổi.
PATCH /user	Status code phù hợp với kết quả	Bảng khảo sát ghi nhận 200 khi cập nhật thành công và 422 khi validation thất bại.

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
GET /user/{account_id} GET /users/{username}	Status code phù hợp với kết quả	200 khi tìm thấy user; 404 khi không tìm thấy.
GET /users	Status code phù hợp với kết quả	200 khi liệt kê thành công; 304 khi dữ liệu không đổi.
GET /users/{username}/hovercard	Status code phù hợp với kết quả	200 thành công; 404 không tìm thấy; 422 validation thất bại hoặc endpoint bị spam.
Sáu endpoint Users	Không biểu diễn lỗi bằng 200 + error body	Báo cáo ghi nhận status code lỗi riêng; chưa kiểm thử runtime mọi phản hồi.

4. Idempotency rõ ràng - Chưa đủ cơ sở kết luận

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
PATCH /user	Tài liệu hóa idempotency và retry an toàn	Có các trường cập nhật name, email, blog, twitter_username, company, location, hireable, bio; tài liệu không nêu cam kết idempotency hoặc hướng dẫn retry an toàn. Chưa đủ cơ sở kết luận về PATCH /user.
GET /user; GET /user/{account_id}; GET /users; GET /users/{username}; GET /users/{username}/hovercard	Tính an toàn của thao tác tạo/cập nhật/xóa	Đây là các endpoint GET; yêu cầu POST/PUT/DELETE của checklist không áp dụng trực tiếp.
Không có trong sáu endpoint	POST + Idempotency-Key; PUT/DELETE	Phạm vi khảo sát không có endpoint POST, PUT hoặc DELETE; các yêu cầu tương ứng không áp dụng.

5. Error response có cấu trúc - Chưa đạt

Endpoint	Yêu cầu kiểm tra	Bằng chứng / kiểm tra
GET /user	Error response có cấu trúc (type, title, detail, instance)	Gọi thất: HTTP 401, message = Requires authentication. Không gửi Authorization. Content-Type: application/json; charset=utf-8. Body có message, documentation_url, status (chuỗi); thiếu type, title, detail, instance.
PATCH /user	Error response có cấu trúc (type, title, detail, instance)	Gọi thất: HTTP 401, message = Requires authentication. Không gửi Authorization; body {}. Chưa kiểm tra 422 sau xác thực. Content-Type: application/json; charset=utf-8. Body có message, documentation_url, status (chuỗi); thiếu type, title, detail, instance.
GET /user/{account_id}	Error response có cấu trúc (type, title, detail, instance)	Gọi thất: HTTP 404, message = Not Found. account_id = 9223372036854775807; không gửi Authorization. Content-Type: application/json; charset=utf-8. Body có message, documentation_url, status (chuỗi); thiếu type, title, detail, instance. Chưa đạt theo checklist.
GET /users	Error response có cấu trúc (type, title, detail, instance)	Gọi thất: HTTP 401, message = Bad credentials. per_page=1; gửi Bearer token giả để tạo lỗi xác thực. Đây là lỗi tâng xác thực. Content-Type: application/json; charset=utf-8. Body có message, documentation_url, status (chuỗi); thiếu type, title, detail, instance.
GET /users/{username}	Error response có cấu trúc (type, title, detail, instance)	Gọi thất: HTTP 404, message = Not Found. username = soa-criterion5-nonexistent-20261006-8f6e91; không gửi Authorization. Content-Type: application/json; charset=utf-8. Body có message, documentation_url, status (chuỗi); thiếu type, title, detail, instance.
GET /users/{username}/hovercard	Error response có cấu trúc (type, title, detail, instance)	Gọi thất: HTTP 401, message = Requires authentication. username = octocat; không gửi Authorization. Chưa kiểm tra 422 sau xác thực. Content-Type: application/json; charset=utf-8. Body có message, documentation_url, status (chuỗi); thiếu type, title, detail, instance.

6. Pagination rõ ràng - Đạt

Endpoint	Yêu cầu kiểm tra	Bằng chứng / kiểm tra
GET /users	Cơ chế phân trang	Tài liệu endpoint nêu rõ phân trang chỉ dùng since (user ID) và dùng Link header để lấy URL trang tiếp theo.

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
GET /users	Giới hạn kích thước trang	per_page mặc định 30 và tối đa 100; since là cursor phân trang, không phải page index.
GET /user PATCH /user GET /user/{account_id} GET /users/{username} GET /users/{username}/hovercard	Pagination collection	Endpoint trả singleton, một user hoặc ngữ cảnh của user; không phải collection cần phân trang.

7. Filter/Sort đa dạng - Chưa đạt

Endpoint	Yêu cầu kiểm tra	Bảng chứng / kiểm tra
GET /users	Filter theo field chính	since giới hạn kết quả theo user ID lớn hơn giá trị đưa vào; tài liệu xác định đây là cơ chế phân trang, không phải bộ lọc đa thuộc tính.
GET /users	Sort đa trường	Danh sách theo thứ tự đăng ký trên GitHub; không ghi nhận tham số sort tùy chọn hoặc sort đa trường.
GET /users	Sparse fieldsets	Không ghi nhận query parameter để chọn tập field trả về.
GET /users/{username}/hovercard	Query filter/sort	subject_type và subject_id bổ sung ngữ cảnh cho hovercard; không thao tác trên collection hoặc điều khiển sắp xếp.
GET /user PATCH /user GET /user/{account_id} GET /users/{username}	Filter/Sort collection	Endpoint trong phạm vi trả một tài nguyên, không liệt kê collection.

8. Authentication & Security - Đạt

Endpoint	Yêu cầu kiểm tra	Bằng chứng / kiểm tra
GET /user	Xác thực và quyền theo endpoint	Yêu cầu xác thực để lấy user hiện tại; read:user hoặc user scope của token classic cho response riêng tư.
PATCH /user	Xác thực và quyền theo endpoint	Cập nhật hồ sơ; fine-grained token cần quyền Profile: write.
GET /user/{account_id}	Xác thực và quyền theo endpoint	Có thể gọi không xác thực với dữ liệu công khai; một số Enterprise Managed User cần quyền tổ chức.
GET /users	Xác thực và quyền theo endpoint	Có thể gọi không xác thực nếu chỉ lấy dữ liệu công khai.
GET /users/{username}	Xác thực và quyền theo endpoint	Dữ liệu công khai có thể lấy không xác thực; xác thực bằng chính user cho số liệu follower/following của profile riêng tư.
GET /users/{username}/hovercard	Xác thực và quyền theo endpoint	OAuth app/PAT classic cần repo scope; GitHub App và fine-grained token không dùng được endpoint này.
Sáu endpoint Users	Token trong header, không trong URL	Request xác thực dùng Authorization header; báo cáo không ghi nhận truyền token trong URL/query.
Sáu endpoint Users	Rate limit rõ ràng	Báo cáo ghi mức cơ bản 60 request/giờ không xác thực và 5.000/giờ người dùng xác thực; theo dõi qua x-ratelimit-limit, remaining, reset; vượt giới hạn có thể trả 403/429. Mức thực tế tùy loại token/ứng dụng.

9. Versioning + Deprecation - Chưa đạt hoàn toàn

Endpoint	Yêu cầu kiểm tra	Bằng chứng / kiểm tra
GET /user PATCH /user GET /user/{account_id} GET /users GET /users/{username} GET /users/{username}/hovercard	Version prefix trong URL	Path không chứa version prefix như /v1.

Endpoint	Yêu cầu kiểm tra	Bằng chứng / kiểm tra
Sáu endpoint Users	Version header	Request mẫu dùng X-GitHub-API-Version: 2026-03-10; version được đặt trong header.
API version áp dụng cho sáu endpoint	Deprecation/Sunset	GitHub mô tả thời hạn hỗ trợ, Deprecation/Sunset và phản hồi 410 Gone khi phiên bản hết hỗ trợ. Phiên bản 2026-03-10 chưa có ngày sunset được công bố; đây không phải bằng chứng cho thấy thiếu chính sách ngừng hỗ trợ.

4. Kết luận

Trong phạm vi sáu endpoint thuộc nhóm Users của GitHub REST API, 4/9 tiêu chí đạt, gồm: dùng danh từ trong URL, status code đúng nghĩa, pagination rõ ràng và authentication & security. 4/9 tiêu chí chưa đáp ứng đầy đủ, gồm: naming nhất quán, cấu trúc của các phản hồi lỗi đã kiểm tra, filter/sort và version prefix trong URL theo checklist. 1/9 tiêu chí chưa đủ cơ sở kết luận là idempotency của PATCH /user; các yêu cầu riêng cho POST, PUT và DELETE không áp dụng trong phạm vi này.

Vì vậy, API đáp ứng một phần checklist và còn những điểm cần cải thiện hoặc bổ sung tài liệu. Kết luận này chỉ áp dụng cho phạm vi Users và các bằng chứng đã khảo sát.